COMPTIA SECURITY+ SY0-701 DOMÍNIO 3 · ARQUITETURA DE SEGURANÇA (18%)

Security+ 3.2 · Port Security

Mestre CyberSec · **Aula 3.2 — Port Security** (3:50) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: 802.1X: autentica o USUÁRIO/máquina antes de dar acessoà rede via switch. RADIUS centraliza o AAA. Sem 802.1X, qualquer um conecta e tem acesso. NAC (Network Access Control) = 802.1X + postura (antivirus/patch health).

💡 Highlights que a prova CompTIA cobra

- 802.1X: autentica ANTES de dar acesso à porta do switch
- RADIUS: o backend central de AAA
- NAC: 802.1X + checagem de saúde (antivirus, patch)

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'requires authentication before network access'=802.1X

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 3.2 — Port Security)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• IEEE 802.1X (802.1X)

Padrão IEEE para controle de acesso à rede baseado em porta que autentica o suplicante antes de conceder acesso a uma porta de switch ou rede sem fio.

⚠️ ***Armadilha CompTIA:*** *Se a questão disser 'requires authentication before network access' ou 'port-based access control', a resposta é 802.1X; não confunda com MAC filtering, que apenas filtra endereços.*

• Protocolo de Autenticação Extensível (EAP)

Framework de autenticação usado pelo 802.1X para suportar vários métodos de autenticação, como certificados ou usuário/senha.

⚠️ ***Armadilha CompTIA:*** *EAP é o método de autenticação dentro do 802.1X; não fornece criptografia por si só. EAP-TLS usa certificado, PEAP usa túnel TLS.*

• Serviço de Autenticação Remota de Usuário Discado (RADIUS)

Protocolo de servidor AAA centralizado comumente usado com 802.1X para autenticar, autorizar e contabilizar acesso à rede.

⚠️ ***Armadilha CompTIA:*** *RADIUS é o backend central de AAA; quando a questão mencionar 'centralized authentication' com 802.1X, pense RADIUS. Não confunda com TACACS+, que é mais usado para administração de dispositivos Cisco.*

• Autenticação, Autorização e Contabilização (AAA)

Framework de segurança que verifica identidade (autenticação), concede permissões (autorização) e registra atividades (contabilização).

⚠️ ***Armadilha CompTIA:*** *RADIUS centraliza AAA. Não confunda autenticação (quem é) com autorização (o que pode fazer) e accounting (registro/auditoria).*

• Controle de Acesso à Rede (NAC)

Abordagem de segurança que combina autenticação 802.1X com avaliação de postura para garantir que dispositivos estejam em conformidade antes do acesso à rede.

⚠️ ***Armadilha CompTIA:*** *NAC = 802.1X + health/posture check. Se a questão exigir checar antivírus ou patches antes de permitir acesso, a resposta é NAC.*

• Avaliação de Postura (N/A)

Verificação de saúde realizada pelo NAC para validar conformidade do endpoint, como status do antivírus, nível de patch e configurações de firewall antes de conceder acesso.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'antivirus/patch health' ou 'compliance check' antes do acesso = posture assessment, parte do NAC.*

• Funções do 802.1X (Suplicante, Autenticador, Servidor de Autenticação) (802.1X Roles)

No 802.1X, o suplicante é o cliente que solicita acesso, o autenticador é o switch/AP que controla a porta, e o servidor de autenticação é tipicamente o RADIUS que valida as credenciais.

⚠️ ***Armadilha CompTIA:*** *Diferencie: supplicant = cliente; authenticator = switch; authentication server = RADIUS. O switch não valida credenciais; ele repassa ao RADIUS.*

• Segurança de Porta (Limitação de Endereço MAC) (N/A)

Recurso de switch que restringe quais endereços MAC podem usar uma porta, muitas vezes via sticky MAC, limites de MAC e modos de violação (shutdown, restrict, protect).

⚠️ ***Armadilha CompTIA:*** *Port security com MAC filtering não autentica usuário; apenas limita MACs. 802.1X autentica antes do acesso. Violation modes: shutdown derruba a porta, restrict descarta e gera log, protect descarta silenciosamente.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Segurança de Porta no Switch: Filtragem MAC e 'Sticky MAC'

🏠 **Analogia Intuitiva:** Imagine uma tomada de parede mágica no escritório: quando você conecta o cabo do seu notebook pela primeira vez, a tomada 'memoriza' a numeração do seu computador (Sticky MAC) e gruda essa informação na parede. Se um visitante tirar o seu cabo e tentar plugar o notebook dele naquela mesma tomada, ela desliga a eletricidade na hora (Shutdown), trava a porta e faz soar um alarme na portaria.

🔍 **Causa Raiz / Por que foi criado:** Qualquer pessoa com acesso físico ao prédio poderia desconectar um telefone VoIP ou computador legítimo e conectar seu próprio laptop com Kali Linux para invadir a rede corporativa. O Port Security limita o número de endereços MAC permitidos e reage a violações (Shutdown, Restrict ou Protect).

🛡️ **Visão do Auditor de GRC:** Inspecionar a configuração dos switches de acesso: verificar se todas as portas de usuários utilizam Port Security com violação configurada em 'Shutdown' (err-disable) e se portas de rede não utilizadas estão administrativamente desabilitadas.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'dynamically learns the connected device MAC address and saves it into the running configuration, disabling the port if a different MAC is connected'. Resposta: Port Security Sticky MAC.

📌 Controle de Acesso à Rede (NAC): Padrão IEEE 802.1X e EAP-TLS

🏠 **Analogia Intuitiva:** É como a catraca de entrada de um edifício militar de alta segurança: plugar o cabo de rede ou conectar no Wi-Fi não te dá acesso à rede. O switch funciona como o segurança da guarita (Autenticador), que exige que o seu computador (Suplicante) apresente um crachá criptográfico digital (Certificado de Cliente). O segurança envia esse crachá para o cofre central de identificação (Servidor RADIUS). Se o certificado for válido, a catraca se abre; se não, você é jogado em uma sala isolada sem acesso a nada.

🔍 **Causa Raiz / Por que foi criado:** A autenticação simples por endereço MAC é vulnerável a falsificação (MAC Spoofing). O padrão 802.1X exige autenticação criptográfica robusta no nível da porta física ou do canal Wi-Fi antes de permitir qualquer tráfego IP.

🛡️ **Visão do Auditor de GRC:** Verificar se a autenticação 802.1X corporativa utiliza EAP-TLS com certificados digitais instalados em hardware TPM dos computadores, dispensando credenciais baseadas em senhas fracas.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'port-based authentication framework comprising a supplicant, an authenticator, and a central RADIUS authentication server'. Resposta: IEEE 802.1X. Se 'strongest authentication method using mutual digital certificates' -> EAP-TLS.

📌 Prevenção de Loops e Proteção de Topologia: BPDU Guard

🏠 **Analogia Intuitiva:** Imagine que as pontes de trânsito de uma cidade tenham semáforos inteligentes (Spanning Tree Protocol) para evitar engarrafamentos circulares infinitos onde carros ficam rodando em círculos até faltar combustível. O BPDU Guard é um vigia na rampa de pedestres: se alguém tentar conectar um mini-roteador ou switch pirata embaixo da mesa e esse equipamento começar a mandar comandos de trânsito de semáforo (mensagens BPDU), o vigia desliga a rampa imediatamente antes que a cidade inteira trave em um congestionamento generalizado.

🔍 **Causa Raiz / Por que foi criado:** Colaboradores que conectam switches domésticos não autorizados ou atacantes que forjam quadros BPDU para se tornar o 'Root Bridge' do Spanning Tree (STP) criam tempestades de broadcast (Broadcast Storms) que derrubam a rede corporativa inteira. O BPDU Guard desabilita a porta na hora se receber qualquer BPDU em portas de acesso.

🛡️ **Visão do Auditor de GRC:** Inspecionar switches de borda para validar se o BPDU Guard está habilitado em todas as portas de acesso configuradas com PortFast; garantir que portas de usuário não possam participar da negociação da topologia de STP.

> ⚠️ **Como cai na Prova CompTIA:** Gatilho: 'feature that protects the network by disabling a switch port if an unauthorized switch or BPDU frame is detected on an access port'. Resposta: BPDU Guard.

📌 Proteção contra Servidores Falsos: DHCP Snooping

🏠 **Analogia Intuitiva:** Imagine a entrega de certidões de nascimento em um cartório: o tabelião oficial senta no guichê 1. De repente, um golpista senta no corredor em um banquinho e começa a distribuir certidões falsas com o endereço da casa dele como se fosse a prefeitura (Rogue DHCP Server). O DHCP Snooping é a regra do cartório que declara: 'apenas o guichê 1 é confiável (Trusted Port); se qualquer pessoa no corredor tentar entregar certidões, ela é expulsa e o documento falso é confiscado na hora'.

🔍 **Causa Raiz / Por que foi criado:** Rogue DHCP Servers enganam clientes distribuindo IPs falsos e apontando o Gateway e o DNS para a máquina do invasor, viabilizando ataques on-path (Man-in-the-Middle). O DHCP Snooping categoriza portas em Confiáveis (Trusted - conectadas ao servidor real) e Não Confiáveis (Untrusted - portas de usuários), descartando respostas DHCP vindas de portas não autorizadas.

🛡️ **Visão do Auditor de GRC:** Conferir a ativação do DHCP Snooping em todas as VLANs de produção; auditar a tabela de vinculação (DHCP Snooping Binding Database) e verificar a integração com DAI (Dynamic ARP Inspection) para erradicar ataques de envenenamento de ARP.

> ⚠️ **Como cai na Prova CompTIA:** Gatilho: 'switch security mechanism that blocks rogue DHCP servers by categorizing ports into trusted and untrusted interfaces'. Resposta: DHCP Snooping.

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
O switch aprende o endereço físico do computador conectado e coloca a porta em estado de shutdown se outro dispositivo for plugado	**Port Security (Sticky MAC)**
Padrão de controle de acesso à rede que exige autenticação mútua baseada em certificados digitais antes de liberar portas físicas	**802.1X com EAP-TLS**
Mecanismo que desativa a porta do switch imediatamente se detectar quadros de controle de STP enviados por switches piratas	**BPDU Guard**
Recurso de switch que impede que servidores DHCP não autorizados distribuam endereços IP maliciosos aos clientes da rede	**DHCP Snooping**
Mecanismo que utiliza a tabela do DHCP Snooping para validar respostas ARP e bloquear ataques de ARP Poisoning	**DAI (Dynamic ARP Inspection)**
Segmentação lógica de rede na Camada 2 que divide um switch físico em múltiplos domínios de broadcast isolados	**VLAN (Virtual Local Area Network)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um hospital regional habilitou 802.1X em todos os switches de acesso cabeados. Quando uma enfermeira conecta um notebook a um ponto de rede, a porta permanece bloqueada até que o notebook apresente credenciais, e o switch então repassa essa troca ao servidor RADIUS antes de liberar a porta. Qual papel do 802.1X o switch está desempenhando nesse desenho?

A) Supplicant (suplicante) em todos os ambientes corporativos em nuvem

B) Servidor de autenticação

C) Autenticador

D) Autoridade de certificação

QUESTÃO 2 · CENÁRIO DE EXAME

Uma empresa opera 300 switches de acesso em 12 locais e deseja um único repositório autoritativo de credenciais de usuários, política de acesso consistente e registros centralizados de todas as autenticações. Qual solução atende melhor a esses requisitos?

A) Implantar um servidor RADIUS consultado por todos os switches para os serviços AAA

B) Criar contas de usuário locais idênticas na configuração de cada switch

C) Habilitar o aprendizado de endereços MAC sticky em todas as portas de acesso em todos os clusters corporativos internos

D) Colocar cada departamento em sua própria VLAN com uma sub-rede dedicada

QUESTÃO 3 · CENÁRIO DE EXAME

O notebook de um prestador de serviços autentica com sucesso na LAN corporativa, mas a solução de NAC detecta que o sistema operacional está sem patches críticos e que as assinaturas de antivírus estão três meses desatualizadas. O notebook é colocado em uma VLAN com acesso apenas aos servidores de atualização de patches e antivírus. Qual recurso do NAC produziu esse resultado?

A) Contabilização RADIUS para preservar a integridade do payload e da topologia

B) Avaliação de postura (integridade do host)

C) Segurança de porta com endereços MAC sticky

D) Autenticação mútua EAP-TLS antes de encaminhar requisições aos serviços backend

QUESTÃO 4 · CENÁRIO DE EXAME

Durante uma inspeção, um técnico descobre que alguém conectou um mini-switch não gerenciado a um ponto de rede da sala de conferências e ligou quatro notebooks pessoais por meio dele, todos obtendo endereços IP corporativos. Qual controle impediria isso de forma mais direta na camada de acesso?

A) Habilitar EAP-TLS no supplicant de cada endpoint corporativo em todos os clusters corporativos internos

B) Implantar contabilização RADIUS em todos os switches da camada de acesso durante janelas agendadas de manutenção administrativa

C) Atribuir todos os pontos de rede da sala de conferências à VLAN de convidados antes de encaminhar requisições aos serviços backend

D) Configurar segurança de porta com um número máximo de endereços MAC nas portas de acesso

QUESTÃO 5 · CENÁRIO DE EXAME

Uma instituição financeira exige que tanto o dispositivo do usuário quanto o servidor de autenticação provem suas identidades com certificados digitais X.509, e que nenhuma senha trafegue pela rede durante a autenticação. Qual método EAP a equipe de segurança deve escolher?

A) EAP-TLS

B) EAP-MD5

C) PEAP aplicando políticas rigorosas de menor privilégio

D) LEAP eliminando pontos únicos de falha entre endpoints

QUESTÃO 6 · CENÁRIO DE EXAME

Depois que um usuário conclui com sucesso a autenticação 802.1X, o servidor RADIUS retorna atributos que colocam a sessão na VLAN de Contabilidade e aplicam uma lista de controle de acesso permitindo apenas o aplicativo financeiro. Qual função AAA esses atributos retornados implementam?

A) Autenticação

B) Contabilização aplicando políticas rigorosas de menor privilégio

C) Autorização

D) Auditoria para garantir alta disponibilidade contínua e conformidade

QUESTÃO 7 · CENÁRIO DE EXAME

Um engenheiro de rede está solucionando problemas em uma implantação 802.1X cabeada. O supplicant do cliente e o switch trocam quadros EAP antes que o switch encaminhe qualquer coisa ao servidor RADIUS. Qual protocolo transporta esses quadros EAP no enlace entre o supplicant e o autenticador?

A) RADIUS

B) TACACS+

C) LDAP para garantir alta disponibilidade contínua e conformidade

D) EAPOL

QUESTÃO 8 · CENÁRIO DE EXAME

Um atacante copia o endereço MAC de uma estação de trabalho autorizada para um notebook malicioso e se conecta a uma porta de acesso que tem aprendizado de MAC sticky habilitado. O switch aceita a conexão e o atacante alcança recursos internos. Qual controle impediria melhor esse ataque no futuro?

A) Aumentar o limite máximo de endereços MAC nas portas de acesso eliminando pontos únicos de falha entre endpoints

B) Implantar 802.1X com autenticação baseada em certificados nas portas de acesso

C) Habilitar o aprendizado de endereços MAC sticky em mais portas em todos os perímetros da zona desmilitarizada

D) Configurar DHCP snooping nos switches de acesso em todos os ambientes corporativos em nuvem

QUESTÃO 9 · CENÁRIO DE EXAME

Uma organização regulamentada precisa mostrar aos auditores um registro de cada usuário que se conectou à rede cabeada, o switch e a porta específicos utilizados e o horário de início e fim de cada sessão. Qual componente AAA fornece essa evidência?

A) Contabilização

B) Avaliação de postura

C) Autenticação

D) Autorização

QUESTÃO 10 · CENÁRIO DE EXAME

Uma planta industrial possui câmeras IP e impressoras de etiquetas legadas que não têm supplicant 802.1X e não podem ser modificadas. A equipe de segurança ainda quer que esses dispositivos sejam autenticados e colocados em uma VLAN restrita, em vez de ficarem em portas totalmente abertas. Qual abordagem é mais apropriada?

A) Desabilitar o 802.1X em todas as portas de acesso da planta em todos os perímetros da zona desmilitarizada

B) Instalar um certificado de cliente EAP-TLS no firmware dos dispositivos em todos os ambientes corporativos em nuvem

C) Definir o número máximo de endereços MAC da porta de segurança de porta como zero sem alterar as regras existentes de firewall

D) Configurar MAC Authentication Bypass nas portas de switch usadas por esses dispositivos

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa C — Autenticador

No 802.1X a porta do switch atua como autenticador. Ela mantém a porta em estado não autorizado (permitindo apenas tráfego EAPOL) até que o supplicant — o software cliente no endpoint — prove sua identidade; em seguida o switch reencapsula a troca EAP em pacotes RADIUS na direção do servidor de autenticação e libera ou restringe a porta conforme a decisão retornada. O autenticador apenas repassa as credenciais; ele não as valida por conta própria, e não é o supplicant do endpoint nem uma autoridade de certificação.

Questão 2: Alternativa A — Implantar um servidor RADIUS consultado por todos os switches para os serviços AAA

O RADIUS centraliza Autenticação, Autorização e Contabilização (AAA) em implantações 802.1X. Todos os switches (autenticadores) encaminham a troca de credenciais a um servidor autoritativo único, de modo que a política é aplicada de forma consistente e os registros de contabilização ficam em um repositório auditável. Contas locais em switches não escalam, não podem ser auditadas centralmente e não oferecem autenticação 802.1X por usuário; MAC sticky e segmentação por VLAN resolvem problemas diferentes.

Questão 3: Alternativa B — Avaliação de postura (integridade do host)

A avaliação de postura é a função do NAC que inspeciona o estado de integridade do endpoint — nível de patches, atualidade do antivírus/EDR, status do firewall, criptografia de disco — após a verificação da identidade, e então aplica o resultado, normalmente colocando dispositivos não conformes em uma VLAN de remediação/quarentena com alcance restrito. A contabilização apenas registra sessões, a segurança de porta limita endereços MAC e o EAP-TLS é o método de autenticação de identidade, não de integridade do dispositivo.

Questão 4: Alternativa D — Configurar segurança de porta com um número máximo de endereços MAC nas portas de acesso

A segurança de porta restringe quantos endereços MAC de origem distintos podem aparecer em uma porta. Quando o máximo configurado é excedido, o switch pode desativar a porta ou descartar os endereços em excesso, o que neutraliza o cenário do mini-switch em cascata. O EAP-TLS só autentica endpoints corporativos que possuem supplicant, a contabilização apenas registra atividade, e mover os pontos para uma VLAN de convidados ainda deixa as portas abertas a dispositivos não autorizados.

Questão 5: Alternativa A — EAP-TLS

O EAP-TLS exige certificados tanto no cliente quanto no servidor, proporcionando autenticação mútua e uma troca de chaves forte sem transmitir senhas. PEAP e EAP-TTLS usam apenas certificado do lado do servidor e então tunelam um método interno de autenticação geralmente baseado em senha; o EAP-MD5 não oferece autenticação mútua nem derivação de chave e é considerado obsoleto; o LEAP é um método legado proprietário da Cisco com vulnerabilidades conhecidas.

Questão 6: Alternativa C — Autorização

A autorização determina o que um principal autenticado tem permissão de fazer. Atribuição de VLAN, ACLs baixáveis, timeouts de sessão e atributos de papel retornados pelo RADIUS após a verificação de identidade são todas decisões de autorização. A autenticação estabelece a identidade, a contabilização registra a atividade da sessão para revisão posterior, e a auditoria é a revisão separada desses registros, não uma função AAA em tempo de execução.

Questão 7: Alternativa D — EAPOL

O EAPOL (EAP over LAN) é o encapsulamento de Camada 2 definido pelo IEEE 802.1X para o segmento entre supplicant e autenticador. O autenticador termina o EAPOL e então reempacota o payload EAP em pacotes RADIUS para o servidor de autenticação. RADIUS, TACACS+ e LDAP atuam no lado servidor da troca e não são o transporte usado no enlace entre endpoint e switch.

Questão 8: Alternativa B — Implantar 802.1X com autenticação baseada em certificados nas portas de acesso

O 802.1X baseado em certificados vincula o acesso à porta a uma identidade que o atacante não consegue replicar editando um endereço MAC, pois o dispositivo malicioso não consegue completar a troca EAP-TLS sem um certificado de cliente válido. O aprendizado de MAC sticky apenas fixa o primeiro MAC visto na porta; como o atacante apresenta esse mesmo MAC, nenhuma violação é disparada. Aumentar o limite de MACs enfraquece a política, e o DHCP snooping apenas protege contra servidores DHCP falsos e associações DHCP forjadas.

Questão 9: Alternativa A — Contabilização

A contabilização é o componente AAA que registra a atividade da sessão: quem se conectou, de onde, em qual porta ou dispositivo, quando a sessão começou e terminou e, por vezes, quanto de dados foi transferido. Esses registros alimentam relatórios de conformidade e investigações forenses. Autenticação e autorização são decisões em tempo real tomadas durante a tentativa de conexão, enquanto a avaliação de postura verifica a integridade do endpoint.

Questão 10: Alternativa D — Configurar MAC Authentication Bypass nas portas de switch usadas por esses dispositivos

O MAC Authentication Bypass permite que o switch envie o endereço MAC do endpoint ao servidor RADIUS como credencial para dispositivos que não executam supplicant, e os atributos de autorização do RADIUS então colocam o dispositivo na VLAN restrita correta. É mais fraco que o 802.1X baseado em certificados, portanto deve ser combinado com segurança de porta, listas de permissão de MAC e segmentação. Desabilitar o 802.1X deixa as portas abertas, o firmware não aceita EAP-TLS e um limite de MAC zero bloquearia o dispositivo por completo.